

CSIT302 Cybersecurity

Day 2-2 – Lateral Movement & Privilege Escalation

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Lateral Movement

- Lateral movement
 - Attackers will ***move from a device to a device*** after the initial intrusion with the hopes of accessing high-valued data.
 - They will also be looking at ways in which they can gain *additional control of the victim's network*.
 - At the same time, they will be trying not to trigger alarms or raise any alerts.

(External) Reconnaissance

Compromising System

Lateral Movement

Privilege Escalation

Concluding the mission

Lateral Movement

- Lateral movement

- The attacks are carried out ***within an organization's*** network, systems, and premises.
- This phase of the attack can *take a long time*.
 - ✓ In highly complicated attacks, the phase takes several months in order for the hackers to reach the desired target device.
- This involves scanning a network for other resources, the collecting and exploiting of credentials, or the collection of more information for exfiltration.

Internal Reconnaissance

- Internal reconnaissance *is done on-site*.
 - An attacker interacts with the actual target systems in order to find out information about its vulnerabilities using ***sniffing and scanning tools*** to find the data servers and the IP addresses of hosts they can infect.
 - Internal reconnaissance is still a passive attack since the aim is to find information that can be used in future for an even more serious attack.
 - Internal reconnaissance is *used to determine the security mechanisms are in place to ward off hacking attempts*.
 - ✓ Most organizations never install enough security tools and hackers keep on finding ways to hack through the already-installed ones.

Internal Reconnaissance

- Sniffing Tools

- Sniffing generally refers to ***the act of eavesdropping on traffic*** in a network.
- Sniffing tools are designed to *capture the packets* being transmitted over a network and to perform analysis on them, which is then presented in a human-readable format.
- **Wireshark**
 - ✓ The most popular sniffing tool with a user-friendly interface and powerful packet interpretation.
- **Tcpdump**
 - ✓ The most powerful packet-filtering capabilities and can even selectively capture Packets.

Scanning Tools

- Nmap

- Attackers will try to map out the hosts in a network in order to discover the ones that contain valuable information.

- Nessus

- The known best network scanners and vulnerability scanner for white hats.
- It scans a network and shows connected devices that have *misconfigurations and missing patches*.
- The tool shows the devices that are using their default passwords, weak passwords, or have no passwords at all and recovers passwords from some devices by launching an external tool to help it with dictionary attacks against targets in the network.
- Lastly, the tool is able to show abnormal traffic in the network.
- Example of the report (https://virginia.service-now.com/its?id=itsweb_kb_article&sys_id=75e70054dbb553404f32fb671d9619d5)

Nmap Overview

- Nmap (<https://nmap.org>) is a free and open source utility for network discovery and security auditing.
- Nmap uses raw IP packets in novel ways to determine
 - what hosts are available on the network,
 - what services (application name and version) those hosts are offering,
 - what operating systems (and OS versions) they are running,
 - what type of packet filters/firewalls are in use,
 - and dozens of other characteristics.
- The Nmap suite includes
 - Zenmap: an advanced GUI and results viewer

Nmap Overview

- Basic functions of Nmap

- Basic command: `nmap <option> <target IP Address>`

- <target IP Address>

- A single host: 192.168.2.4

- Groups of IP addresses

- ✓ A network using CIDR notation: 192.168.1.0/24

- ✓ Range of IP addresses: 192.168.3-5,7.1 (This implies 192.168.3.1, 192.168.4.1 , 192.168.5.1 and 192.168.7.1)

- ✓ List of IP addresses: 10.0.2.4 10.0.2.5 10.0.2.15

Nmap Overview

- `<option>`
 - Scanning options:
 - ✓ `-sS` : TCP SYN scan. There are more options for TCP scan.
 - ✓ `-sU` : UDP scan
 - ✓ Scanning outputs will be open, closed, filtered, unfiltered or their combinations.
 - Timing options: `-T <mode>`
 - ✓ Paranoid (0), Sneaky (1), Polite (2), Normal (3), Aggressive (4), Insane (5)
 - ✓ The time interval between two consecutive packets sent to the target are getting shorter as the number increases.
 - ✓ For example, in Paranoid mode, a packet is sent every 5 minutes and no packets sent in parallel for IDS evasion. In Insane mode, *Nmap* will not wait for more than 0.3 seconds for a response.

Nmap Overview

➤ Port specification

- ✓ By default, Nmap will scan the most common 1000 ports in a random order
- ✓ Other options are: `-p port range`: Scan only the defined ports
 - `-F` : Scan only 100 most common ports (fast)
 - `-r` : Do not randomize port numbers
 - `--top-ports N` : Scan the most common N ports

➤ OS Detection (-O): Enable OS detection (This may require a sudo privilege for the user)

➤ Verbose mode (-v): print out more information on the scanning.

➤ No ping (-PN): skip network discovery stage

➤ Host scan: No port scan (-sn), arp scan (-sP)

➤ Version detection (-sV)

Nmap Overview

- From version 7, Nmap comes equipped with script function, which makes Nmap more powerful and useful for pentesters.
- Commands for script function:

```
nmap --script <script name> <target url or ip>
```
- The scripts cover the following categories:
 - **Auth:** Use to test whether you can bypass authentication mechanism
 - **Broadcast:** Use to find other hosts on the network and automatically add them to scanning que.
 - **Brute:** Use for brute password guessing.
 - **Discovery:** Use to discover more about the network.
 - **Dos:** Use to test whether a target is vulnerable to DoS

Nmap Overview

- The scripts cover the following categories:
 - **Exploit:** Use to actively exploit a vulnerability
 - **Fuzzer:** Use to test how server responds to unexpected or randomized fields in packets and determine other potential vulnerabilities
 - **Intrusive:** Use to perform more intense scans that pose a much higher risk of being detected by admins.
 - **Malware:** Use to test target for presence of malware
 - **Safe:** Use to perform general network security scan that's less likely to alarm remote administrators
 - **Vuln:** Use to find vulnerabilities on the target

Nmap Practice

- You need at least two virtual machines with VirtualBox or VMware:
 - One with Nmap (Pentester's PC)
 - One with Vulnerabilities (The target)
 - Put both PC in the same virtual segmentation using "NAT Network".



Pentester's PC

Vulnerability Scan



The target

Nmap Practice

- Nmap is portable
 - Most operating systems are supported, including Linux, Microsoft Windows, FreeBSD, OpenBSD, Solaris, IRIX, Mac OS X, HP-UX, NetBSD, Sun OS, Amiga, and more.
 - You can choose Kali, which is a famous offensive operating system and has Nmap as a default.
 - You also can install Nmap to the other OS such as Ubuntu, which is one of the most popular Linux distribution.
 - ✓ To install: `sudo apt-get install nmap`

Nmap Practice

- One of the simplest ways to get machines with a lot of vulnerabilities is installing *metasploitable*.
 - *Metasploitable* is an intentionally vulnerable Linux virtual machine that can be used to conduct security training, test security tools, and practice common penetration testing techniques.
 - You can download metasploitable 2 in <https://sourceforge.net/projects/metasploitable/>
 - [Warning] Do not leave metasploitable VM is running, if you are not using it.

Nmap Practice

- Steps:
 - Find the target host: Host only scan
 - Detect the OS version of the target system
 - Find open ports and their current software versions
 - Find vulnerabilities using `--script vuln` option
 - Find the details of vulnerabilities in CVE websites.

Avoiding Alerts

- **Network Intrusion Detection Systems (NIDSs)** shields their systems to prevent internal recon. But, it has a limited capability when the hackers are scanning individual targets.
- Host-based intrusion detection systems can prevent the scan from happening. However, most network administrators will not consider Host-based intrusion detection systems in a network, especially if the number of hosts is huge.

Avoiding Alerts

- If network administrators detect that there is a threat on the network, they will thoroughly sweep through it and thwart any progress that the attacker will have made.
- Security tools can identify many signatures of hacking tools and malware that hackers have been using.
- ***By using legitimate tools for lateral movement***
 - Security systems ignore them since they are legitimate.
 - It allows the hackers to move around in highly secured networks.
 - For example, download the file on the web directly using *Windows PowerShell*.

Performing Lateral Movement

- Sysinternals

- A suite of tools that allows administrators to control Windows-based computers from a remote terminal.
- Attackers use *Sysinternals* to upload, execute, and interact with executables on remote hosts. Those commands can be automated using scripts.
- It *does not give alerts to users* on a remote system when it is in operation.
- It is classified as **legitimate system admin tools** and therefore are ignored by antivirus programs.
- It can be used to reveal information about running processes and, if needed, kill them or stop services.
- It still can be downloaded in (<https://docs.microsoft.com/en-us/sysinternals/downloads/sysinternals-suite>)

Performing Lateral Movement

- File sharing
 - Performing lateral movement in networks that they have already compromised **to capture most of the data available** in a network.
 - Using *legitimate file sharing* protocol gives hackers the advantage of low probability of detection since these are legitimate traffic channels that are normally not monitored.
 - It also can be used to **plant other bugs (malware)** in the shared environment to infect the computers that copy files.
 - More effective when the attackers have administrator privileges.

Performing Lateral Movement

- Remote Desktop (Windows)

- Another legitimate way which is used to access and control computers remotely
- It can be abused by hackers for the purpose of lateral movement.
- Remote Desktop can be launched when hackers have already compromised a computer inside a network and allows to steal data, disabling security software, or install malware.
- Pros
 - ✓ A full interactive **graphical user interface (GUI)**
 - ✓ Fully encrypted and therefore **opaque to any monitoring systems**
- Cons
 - ✓ A user working on the remote computer can tell when an external person has logged on to the computer → Use Remote Desktop at times when **no users are physically on the target.**

Performing Lateral Movement

- PowerShell
 - A powerful built-in, object-oriented scripting tool that is available in modern versions of Windows. (legitimate and not detectable)
 - Several hacking-and security-oriented PowerShell modules such as *PowerSploit* (<https://github.com/PowerShellMafia/PowerSploit>) and *Nishang* (<https://github.com/samratashok/nishang>) are being used today.
- How breaches are made by PowerShell:
 - The hackers deployed PowerShell scripts to run as scheduled tasks on Windows machines.
 - The scripts were passed to PowerShell through its command line interface so they did not trigger antivirus programs.
 - The scripts, once executed, downloaded an executable and then were run from a remote access tool.
 - No traces would be left for forensic investigators and they left minimal footprints.

Performing Lateral Movement

- Windows Management Instrumentation (WMI)
 - WMI is Microsoft's inbuilt framework that manages the way in which Windows systems are configured. (legitimate and not detectable)
 - The framework can be used to **start processes remotely**, to **make system information queries**, and also **store persistent malware** if the hacker already has access to the machine.
 - WMI was a key tool in a famous hack on Sony Pictures in 2014.
 - WMIImplant (<https://github.com/FortyNorthSecurity/WMIImplant>) is an example of a hacking tool based on the WMI framework.
 - ✓ WMIImplant enables a hacker to give cmd commands, get outputs, modify the registry, run PowerShell scripts, and finally, create and delete services.

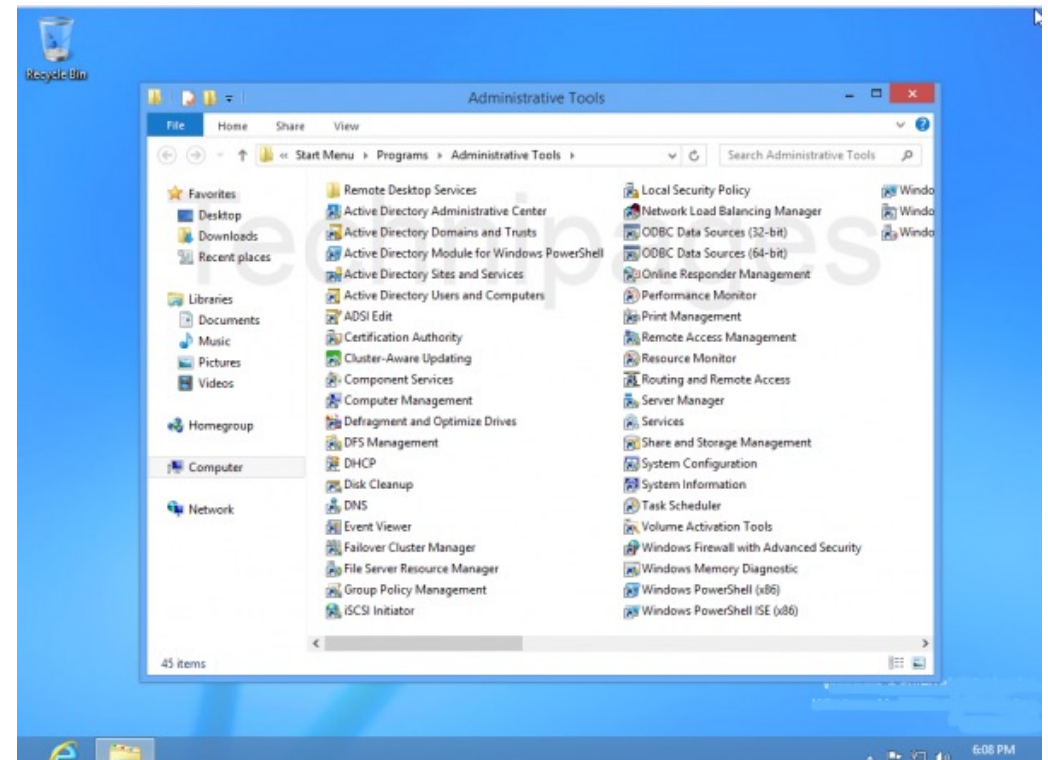
Performing Lateral Movement

- Scheduled tasks (In Windows)
 - It needs SYSTEM user privileges to be performed.
 - Attackers can use to steal data over time without raising alarms.
- Remote Registry
 - Registry gives control over both the hardware and software of a Windows machine.
 - The Registry can be remotely edited to disable protection mechanisms, disable auto-start programs such as antivirus software, and to install configurations that support the uninterrupted existence of malware.

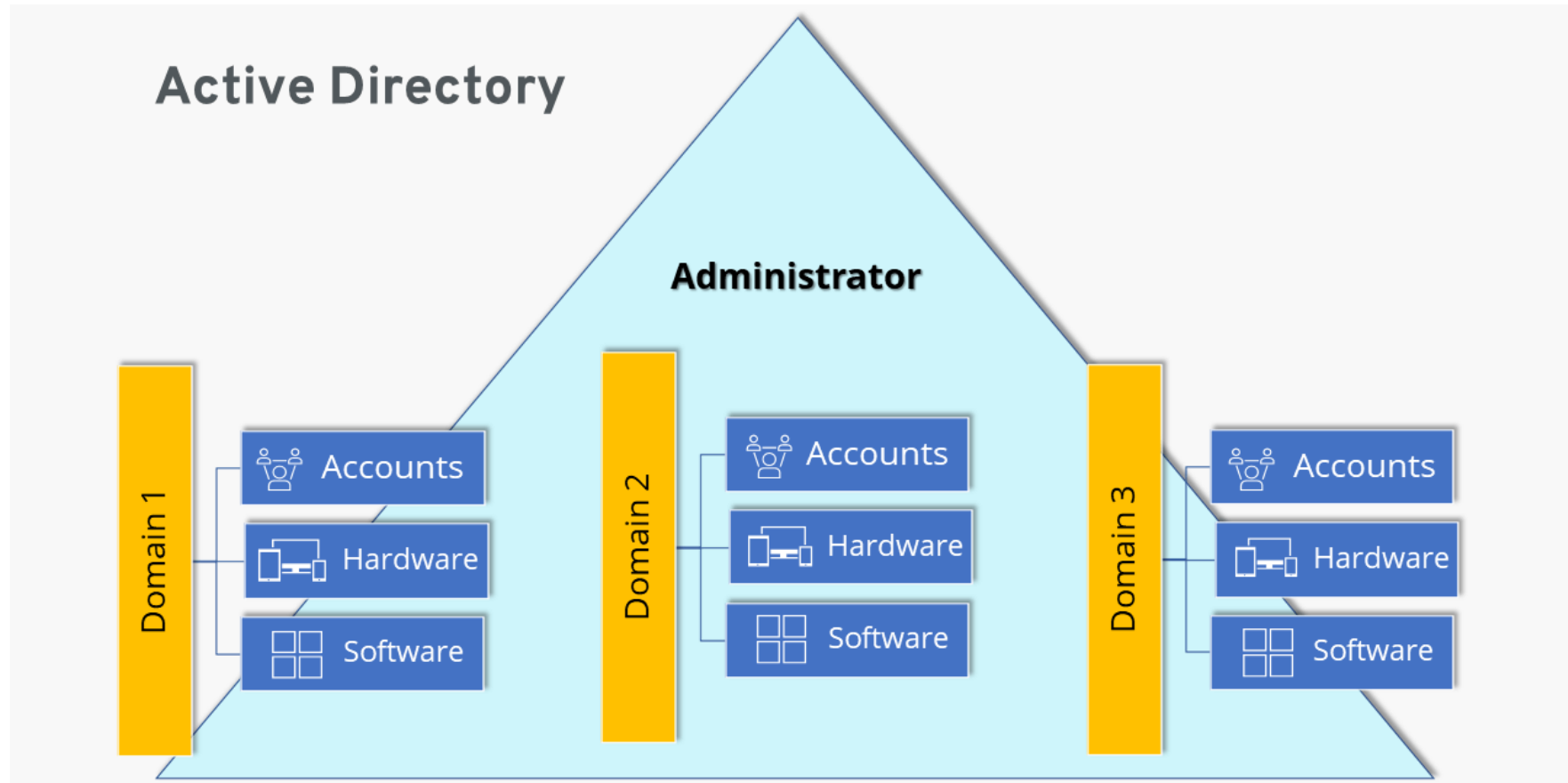
Performing Lateral Movement

- Active Directory

- Active Directory (AD) is a directory service that Microsoft developed **for the Windows domain networks.**
- It is included in most Windows Server operating systems as a set of processes and services.
- Initially, Active Directory was only in charge of centralized domain management. But Active Directory became an umbrella title for a broad range of **directory-based identity-related services.**



Active Directory



Performing Lateral Movement

- Active Directory

- *The richest source of information for the devices connected to a domain network* → a key target of an attack.
- *The AD stores the names of users in a network alongside their roles in an organization and allows administrators to change passwords and privileges for users in a network.*
- PowerShell commands (from PyroTek3, <https://github.com/PyroTek3/PowerShell-AD-Recon>) and *mimikatz* can be used for the reconnaissance on the AD environment and to obtain information about the Kerberos tickets.
- Also known vulnerabilities such as MS14-068 (<https://docs.microsoft.com/en-us/security-updates/securitybulletins/2014/ms14-068>) can be used to get an administrator privilege.

Performing Lateral Movement

- Breached host analysis
 - The attacker will look around on the breached computer for any information that can help him/her move further with the attack such as **passwords** stored in browsers and text files, **logs** and **screen captures**.
- Central administrator consoles
 - The attacker can make less effort to control a device of interest from a console instead of having to break into it every single time. This is the reason why ATM controllers, POS management systems, network administration tools and **active directories** are primary targets of hackers.

Performing Lateral Movement

- Email pillaging
 - A huge amount of sensitive information about an organization is stored in emails in the correspondence between employees.
 - From emails, a hacker can collect information about individual users to use it for spear phishing.

Privilege Escalation

- Privilege escalation is the act of exploiting a *bug, design flaw* or *configuration oversight* in an operating system or software application to **gain elevated access** to resources that are normally protected from an application or user.
- Attackers exploit the privileges of the user accounts that they have compromised to achieve a greater objective:
 - Mass deletion, corruption, or theft of data, disabling of computers, destroying hardware, and so on.

Privilege Escalation

- Many system developers have been employing *the least privilege rule*, where they assign users the least amount of privileges that are needed to perform their jobs.
 - Most accounts do not have sufficient rights that can be abused to access or make changes to some files. Hackers will normally **compromise these low-privileged accounts** and, thus, have ***to upgrade them to higher privileges*** in order to access files or make changes to a system.

Privilege Escalation

- Privilege escalation is not a simple phase, as it will at times require the attacker to **use a combination of skills and tools** in order to heighten the privileges.
- There are generally two classifications of privilege escalation: **horizontal** and **vertical** privilege escalation.

(External) Reconnaissance

Compromising System

Lateral Movement

Privilege Escalation

Concluding the mission

Horizontal privilege escalation

- In horizontal privilege escalation, the attacker uses a normal account to access the accounts of other users.
- Two main ways
 - **Through software bugs:** A normal user is able to view and access files of other users due to an error in the coding of a system.
 - **Through an administrator account:** attackers can go on with the attack by creating other admin-level users.
- Horizontal privilege escalation attacks are normally facilitated by tools and techniques that **steal login credentials** at the phase where hackers compromise a system.

Access and Privilege Escalation

- In horizontal privilege escalation,
 - An attacker uses the *same privileges* gained from the initial access.
 - A normal user is erroneously able to *access the account of another user*.
 - Horizontal privilege occurs when an attacker is able to access protected resources using a normal user account.
 - This is normally done through session and cookie theft, cross-site scripting, guessing weak passwords, and logging keystrokes.
 - As a result of this escalation
 - ✓ the attacker normally has well-established remote access entry points into a target system.
 - ✓ The attacker might also have access to the accounts of several users.
 - ✓ The attacker knows how to avoid detection from security tools that the target might have.

Vertical Privilege Escalation

- This type of privilege escalation occurs when the user or process is able to *obtain a higher level of access* than an administrator or system developer intended.
- More difficult, but more rewarding since the attacker can acquire system rights on a compromised system.
- A higher chance of staying and performing actions on a network system whilst remaining undetected. *With super user access rights, an attacker can perform actions that the administrator cannot stop or interfere with.*
- Vertical escalation techniques differ from system to system.
 - In Windows: buffer overflows are commonly used.
 - In Mac: it can be done in a code called jailbreaking.
 - Also, by web-based tools: the exploitation of the code used in the backend.

Vertical Privilege Escalation

- More demanding privilege escalation techniques and includes the **use of hacking tools**.
- However, the attacker should avoid alerts
 - Avoid raising any alarms that the victim system has been compromised. Otherwise, all the efforts that an attacker had made will have been for nothing.
 - Before the attacker performs this phase, it is normal to disable security systems if possible.
 - Or using **legitimate** tools to perform the attack.

Vertical Privilege Escalation

- Privilege escalation technique varies depending on
 - the level of skill that the hacker has.
 - the intended outcome of the privilege escalation process.
- In Windows, administrator access should be rare and normal users should not have administrative access to systems. *Normal employees maintaining admin access open a network to multiple attack vectors.*
- **Remote users** have admin accesses to enable them to troubleshoot and solve some issues. When giving remote users admin access, admins should be cautious enough to ensure that this type of access is not used for privilege escalation.

Vertical Privilege Escalation Methods

- Using valid administrator accounts
 - Attackers gain unauthorized access to an administrator and use it to log in to a sensitive system or create their own logon credentials.
 - Attackers can exploit programming errors, which may introduce vulnerabilities that attackers can bypass security mechanisms.
 - Some systems will accept certain phrases as passwords for all users (such as insecure default password).

Vertical Privilege Escalation Methods

- Access token manipulation
 - Windows normally uses access tokens to determine owners of all running processes.
 - The operating system **logs in** admin users **as normal users**, but **then executes their processes with admin privileges**. Windows uses the `run as administrator` command to execute processes with the privileges of an administrator. → If an attacker can fool the system into believing that processes are being started by an admin, the processes will run without interference with **full-level admin privileges**.
 - If attackers ***cleverly copy access tokens from existing processes*** that are started by admin users in a machine (using built-in Windows API functions) to a new Windows process, access token manipulation can occur.

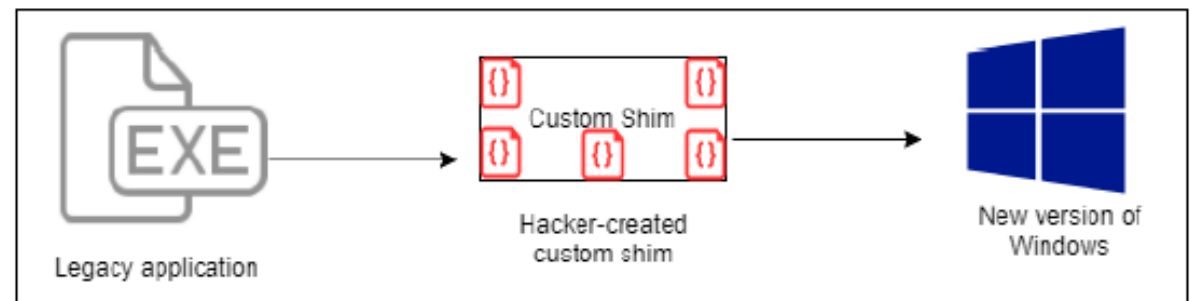
Performing privilege escalation

- Application shimming (1/2)
 - Application shimming is a Windows Application Compatibility framework.
 - Most applications that used to run on Windows XP can today run on Windows 10 due to this framework.
 - The operation of the framework:
 - ✓ It creates a shim to buffer between a legacy program and the operating system.
 - ✓ During execution of programs, the shim cache is referenced to find out whether they will need to use the **shim database**.
 - ✓ The shim database will use an API to ensure that the program's codes are redirected effectively.
 - ✓ Since shims are in direct communication with the OS, Windows decides to add a safety feature where they are designed to run in user mode.

Performing privilege escalation

- Application shimming (2/2)

- Attackers have been able to create **custom shims** that can bypass user account control, inject DLLs into running processes, and meddle with memory addresses.
- These shims can enable an attacker to run their own malicious programs with elevated privileges. They can also be used to turn off security software, especially, the Windows Defender.

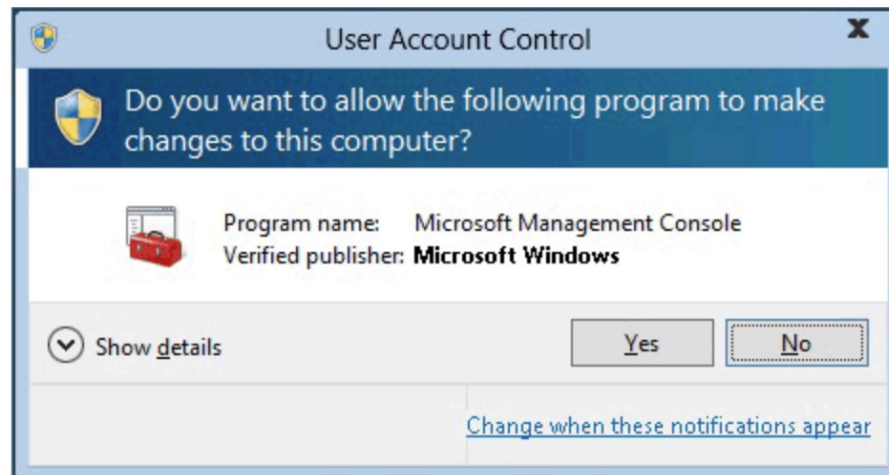


Vertical Privilege Escalation Methods

- Bypassing user account control

- A Windows **User Account Control (UAC)**

- ✓ It acts as a gate between normal users and admin level users.
 - ✓ It is used to give permissions to the program, to elevate their privileges and to run with admin-level privileges.
 - ✓ Typically, Windows prompts the following window and the user needs to enter admin password.



Vertical Privilege Escalation Methods

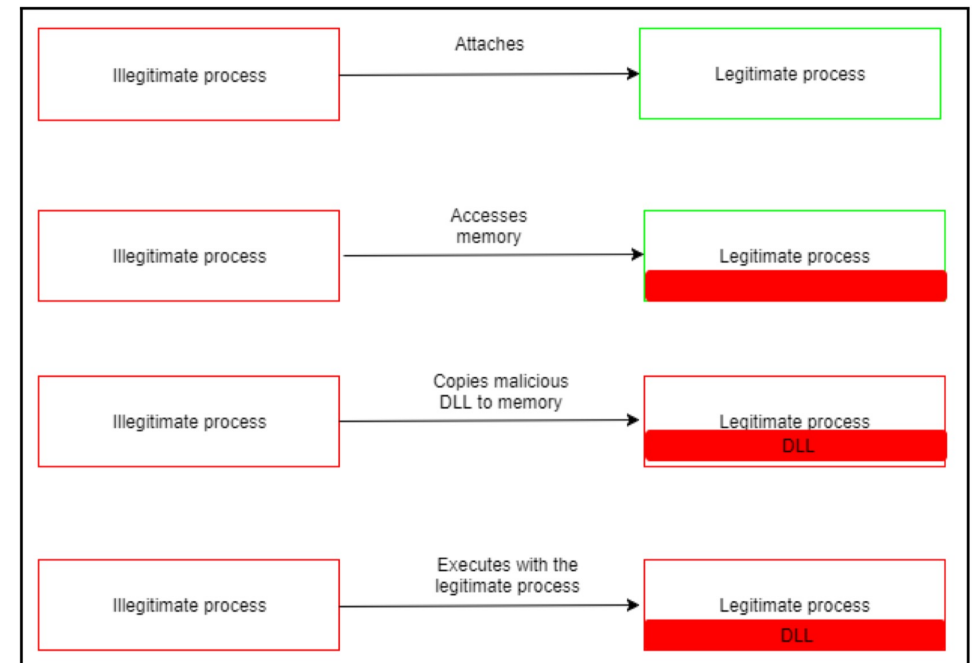
- Some Windows programs are allowed to execute **without prompting a user**.
 - ✓ For instance, *rundll32.exe* is used to load a custom DLL that loads a COM object that has elevated privileges.
 - Note: **DLL** (Dynamic-link library) is a shared library for the Microsoft-based OS. It allows a developer to share code and data without requiring applications to be re-linked or re-compiled. In Apple-based OS, Dylib is used for similar functionality.
 - ✓ Another example is *netplwiz.exe*, which leads to the Windows command execution (cmd.exe) as an administrator. (Search this on the web!)

Performing privilege escalation

- **DLL** (Dynamic-link library) is a shared library for the Microsoft-based OS. It allows a developer to share code and data without requiring applications to be re-linked or re-compiled. In Apple-based OS, Dylib is used for similar functionality.
- DLL injection
 - This is used to run a malicious code using **legitimate** processes and services of the Windows operating system. → The attacker's actions are also masked by the legitimate processes.
 - DLL injection attacks aim to 1) modify the Windows Registry, 2) create threads and 3) do DLL loading, which require admin privileges.

Performing privilege escalation

- Attackers sneak their way into doing them without such privileges in a sequence of:
 - Attaches malicious code → Access Memory → Copy malicious DLL to memory → Execute with legitimate processes
 - DLL injections workflow



Performing privilege escalation

- Reflective DLL injection
 - It loads the malicious code **without having to make the usual Windows API calls** and therefore bypassing DLL load monitoring by sourcing its malicious code in the form of raw data.
 - It is more difficult to detect, even on machines that are adequately protected by security software.
 - https://youtu.be/Ng5OYbk_i-Y
- Examples of malware that use the DLL injection:
 - **Backdoor.Oldrea**: injects itself in the explore.exe process
 - **BlackEnergy**: injects as a DLL into the svchost.exe process
 - **Duqu**: injects itself in many processes to avoid detection

Performing privilege escalation

- DLL search order hijacking
 - Attackers try to **replace legitimate DLLs with malicious ones**.
 - Since the locations where programs store their DLLs can easily be identified, attackers may place malicious DLLs high up in the path traversed to find the legitimate DLL. → When Windows searches for a certain DLL in its normal location, it will find a **DLL file with the same name** but it will not be the **legitimate DLL** (even in the DLLs stored in remote locations)
 - the modification of the ways in which programs load DLLs. Here, attackers modify the *manifest* or the *local direction* files to cause a program to load a different DLL than the intended one.
- DLL hijacking is complex and it requires lots of caution to prevent abnormal behaviour by the victim program. If the abnormal behaviour is detected, it will be reinstalled by a user.

Concluding the mission

Concluding the mission

- Exfiltration

- The attacker will start extracting sensitive data from an organization.
- This could include trade secrets, usernames, passwords, personally identifiable data, top-secret documents, and other types of data.
- Attackers normally steal huge chunks of data in this stage.
- Example of the data exfiltration
 - ✓ Ashley Madison (2015)
 - ✓ Yahoo (Happened in 2013, reported to the public in 2016)
 - ✓ LinkedIn (2016)
- The hackers soon put the data on sale for any interested buyers.
- The hackers could erase or modify the files stored in the compromised computers, systems, and servers

Concluding the mission

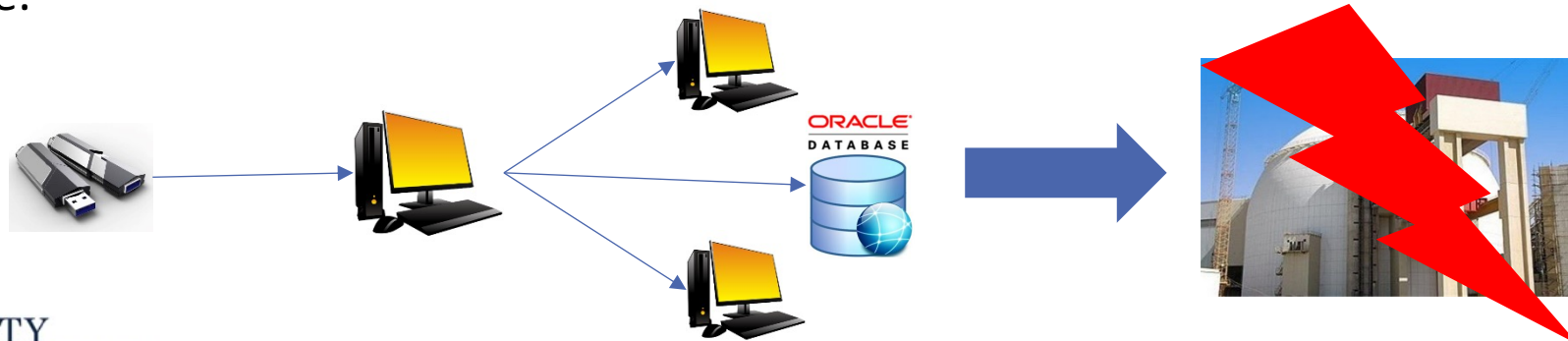
- Sustainment

- The hackers may decide to remain silent even after it exfiltrated all valuable information.
- Attackers install malware, such as rootkit viruses to assure them of access to the victim's computers and systems whenever they want.
- The victim's security tools are at this point ineffective at either detecting or stopping the attack from proceeding.
- The attacker normally has multiple access points to the victims, such that even if one access point is closed, their access is not compromised.

Concluding the mission

- Assault

- most feared stage of any cyber-attack.
- permanently **damage the data and software**, disable or alter the functioning of the victim's hardware.
- Stuxnet attacks on Iranian nuclear facility.
 - ✓ The first recorded digital weapon to be used to wreak havoc on physical resources
 - ✓ The nuclear station was not connected to the Internet. It is transmitted by USB thumb drive.



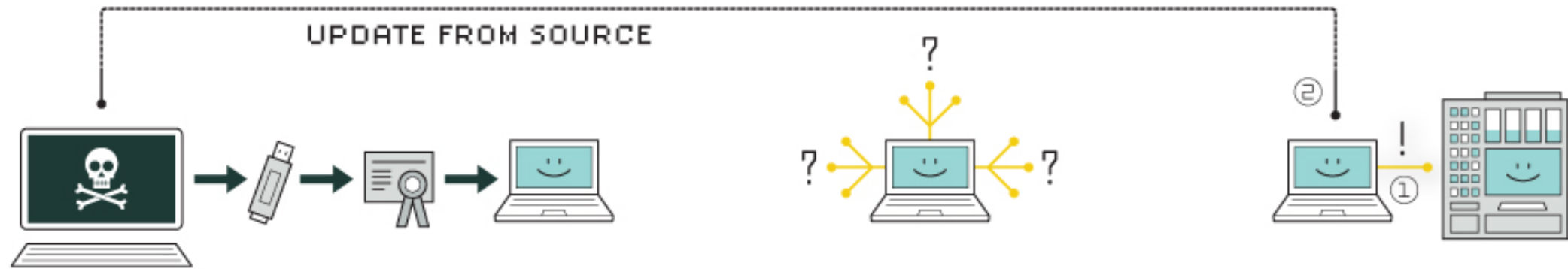
Stuxnet

- Stuxnet is one of the most famous examples of a targeted and government-sponsored cyber attack.
- Stuxnet is only a 500 KB computer worm. It infected the software of at least 14 industrial sites in Iran, including a uranium-enrichment plant.
- This computer worm was at first identified by the security company *VirusBlokAda* in mid-June 2010. The first variant of the worm appeared in June 2009.
- Its current name is derived from a combination of some keywords in the software (".stub" and "mrxnet.sys").
- Stuxnet known to be the first worm that attacks that destroy essential physical infrastructures.

Stuxnet

- Stuxnet attacks a target system in three phases
 - First, it targeted Microsoft Windows machines and networks, repeatedly replicating itself.
 - ✓ Spread through USB thumb drive, then it uses four zero-day vulnerabilities for the propagation.
 - Then, it sought out Siemens Step7 software, which is also Windows-based and used to program industrial control systems that operate equipment (e.g., centrifuges).
 - ✓ Stuxnet infects project files belonging to Siemens' WinCC/PCS 7 control software.
 - ✓ It intercepts communications between the WinCC software running under Windows and the target Siemens PLC devices
 - Finally, it compromised the programmable logic controllers (PLC) .
 - ✓ The target is specific - Siemens S7-300 system and its associated modules.

How Stuxnet worked



1. infection

Stuxnet enters a system via a USB stick and proceeds to infect all machines running Microsoft Windows. By brandishing a digital certificate that seems to show that it comes from a reliable company, the worm is able to evade automated-detection systems.

2. search

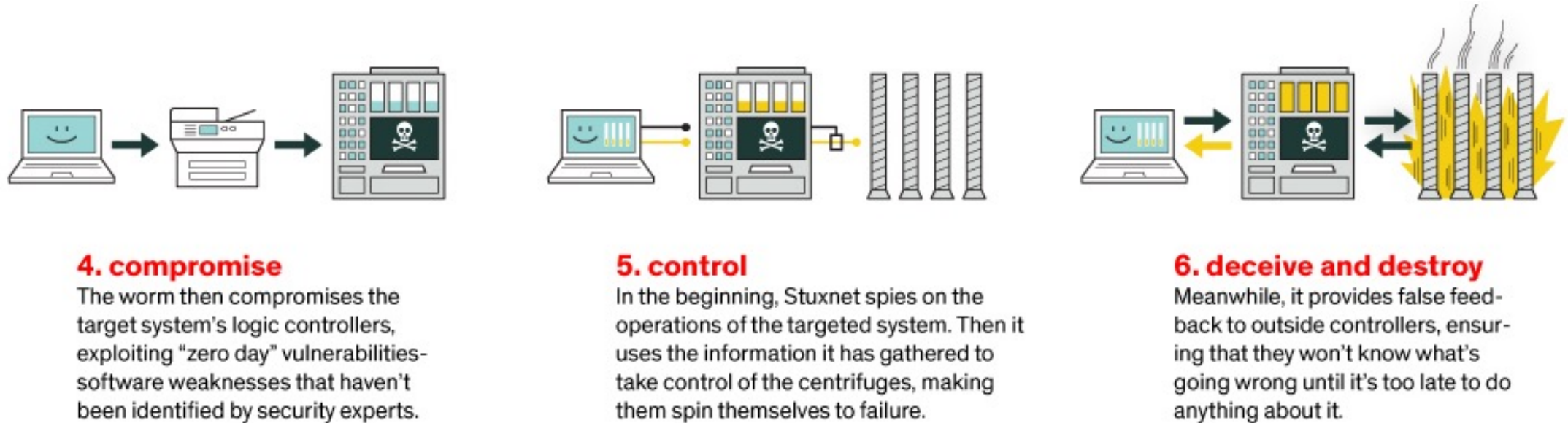
Stuxnet then checks whether a given machine is part of the targeted industrial control system made by Siemens. Such systems are deployed in Iran to run high-speed centrifuges that help to enrich nuclear fuel.

3. update

If the system isn't a target, Stuxnet does nothing; if it is, the worm attempts to access the Internet and download a more recent version of itself.

Source: <https://spectrum.ieee.org/telecom/security/the-real-story-of-stuxnet>

How Stuxnet worked



Source: <https://spectrum.ieee.org/telecom/security/the-real-story-of-stuxnet>

Flame

- Flame is known as a precursor to Stuxnet. It is highly linked to Stuxnet and known to be developed by the same hacking group.
- Flame was 20 MB in total, or some 40 times as big as Stuxnet.
- Flame is a cybersurveillance tool. Its purpose was merely to spy on people.
- Spread over USB sticks, it could infect printers shared over the same network.
- Once Flame had compromised a machine, it could stealthily search for keywords on top-secret PDF files, then make and transmit a summary of the document—all without being detected.

Flame

- Flame is a very sophisticated worm.
 - Data's sent off in smaller chunks: Flame didn't simply transmit the information it harvested all at once to its command-and-control server, because network managers might notice that sudden outflow.
 - Flame could exchange data with any Bluetooth-enabled device: the attackers could steal information or install other malware not only within Bluetooth's standard 30-meter range but also farther out (about 2km) using *Bluetooth rifle*.
 - One of the propagation technique is Windows 7 update: A user would think she was simply downloading a legitimate patch from Microsoft, only to install Flame instead.